

Checklist of controls and compliance

To complete the controls assessment checklist, refer to the information provided in the [Report on scope, objectives and risk assessment](#) For more details about each control, including type and purpose, see the [control categories](#) document.

Next, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control?*

Controls assessment checklist

Yeah	No	Control
☐	☒	The minimum privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewalls
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Software antivirus
☒	☐	Manual supervision, maintenance and intervention for legacy systems.
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, commercial premises, warehouses)
☒	☐	Closed-circuit television (CCTV) surveillance.

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [Report on scope, objectives and risk assessment](#) For more details on each compliance regulation, please refer to the [controls, frameworks and compliance](#) reading.

Next, select “yes” or “no” to answer the question: *Does Botium Toys currently comply with this good compliance practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yeah	No	Good practices
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to improve the security of touchpoints and credit card transaction data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yeah	No	Good practices
☐	☒	EU customer data is kept private and secure.
☐	☒	There is a plan to notify EU customers within 72 hours if their data is compromised or a security breach occurs.
☐	☒	Make sure the data is properly classified and inventoried.

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Apply privacy policies, procedures, and processes to properly document and maintain data. |
|--------------------------|-------------------------------------|---|

Systems and organizational controls (SOC type 1, SOC type 2)

Yeah	No	Good practices
------	----	----------------

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | User access policies are established. |
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☐ | ☒ | Data integrity ensures that the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☒ | The data is available to those authorized to access it. |

This section is *optional* and can be used to provide a summary of recommendations to the IT manager on what controls and/or compliance best practices Botium Toys should implement, based on the risk of not implementing them in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Botium Toys needs encryption for card data and strict user access. The company must create password policies and a disaster recovery plan with backups to meet PCI DSS and GDPR compliance.